Playbook: Respuesta a Incidente de Fuerza Bruta SSH

Objetivo

Proveer una guía accionable y cronológica para detectar, contener, investigar y recuperar ante un ataque de fuerza bruta contra el servicio SSH de los activos monitorizados.

Alcance y disparador

Este playbook se activa cuando el SIEM detecta intentos de acceso no autorizado por fuerza bruta o adivinación de credenciales contra servicios SSH de los hosts monitorizados. Responsable de la respuesta: analista de seguridad.

Información a recolectar

- IP de origen de los intentos.
- Usuario(s) objetivo y número de intentos fallidos.
- Marca de tiempo de inicio y fin del ataque.
- Logs de autenticación del host afectado (auth.log / journald).
- Evidencia de la alerta en el dashboard del SIEM.
- Indicio de algún inicio de sesión exitoso durante el ataque.

Procedimiento de respuesta

Fase	Acción	Responsable
Preparación	Mantener en el SIEM (Wazuh) la recolección de los logs de autenticación, la regla de fuerza bruta SSH y el Active Response activos.	Analista de seguridad
Detección y análisis	Wazuh genera la alerta de fuerza bruta (T1110.001) ante más de 5 intentos fallidos en 60 s desde una misma IP, nivel 10. Validar la alerta, revisar los logs y el dashboard, identificar la IP de origen y confirmar si hubo un inicio de sesión exitoso.	Analista de seguridad
Contención	El Active Response ejecuta firewall-drop y bloquea la IP de origen de forma automática durante el tiempo configurado.	Automático (Wazuh)
Erradicación y recuperación	Si la IP se confirma maliciosa, aplicar bloqueo permanente. Si hubo acceso, revocar sesiones y resetear las credenciales comprometidas. Validar que el servicio opera con normalidad y que no persiste acceso no autorizado.	Analista de seguridad
Actividad post-incidente	Documentar el incidente, endurecer el servicio (deshabilitar el login de root por SSH, exigir autenticación por claves) y ajustar reglas o umbrales de detección si corresponde.	Analista de seguridad

Referencia: MITRE ATT&CK; T1110.001 - Brute Force: Password Guessing.